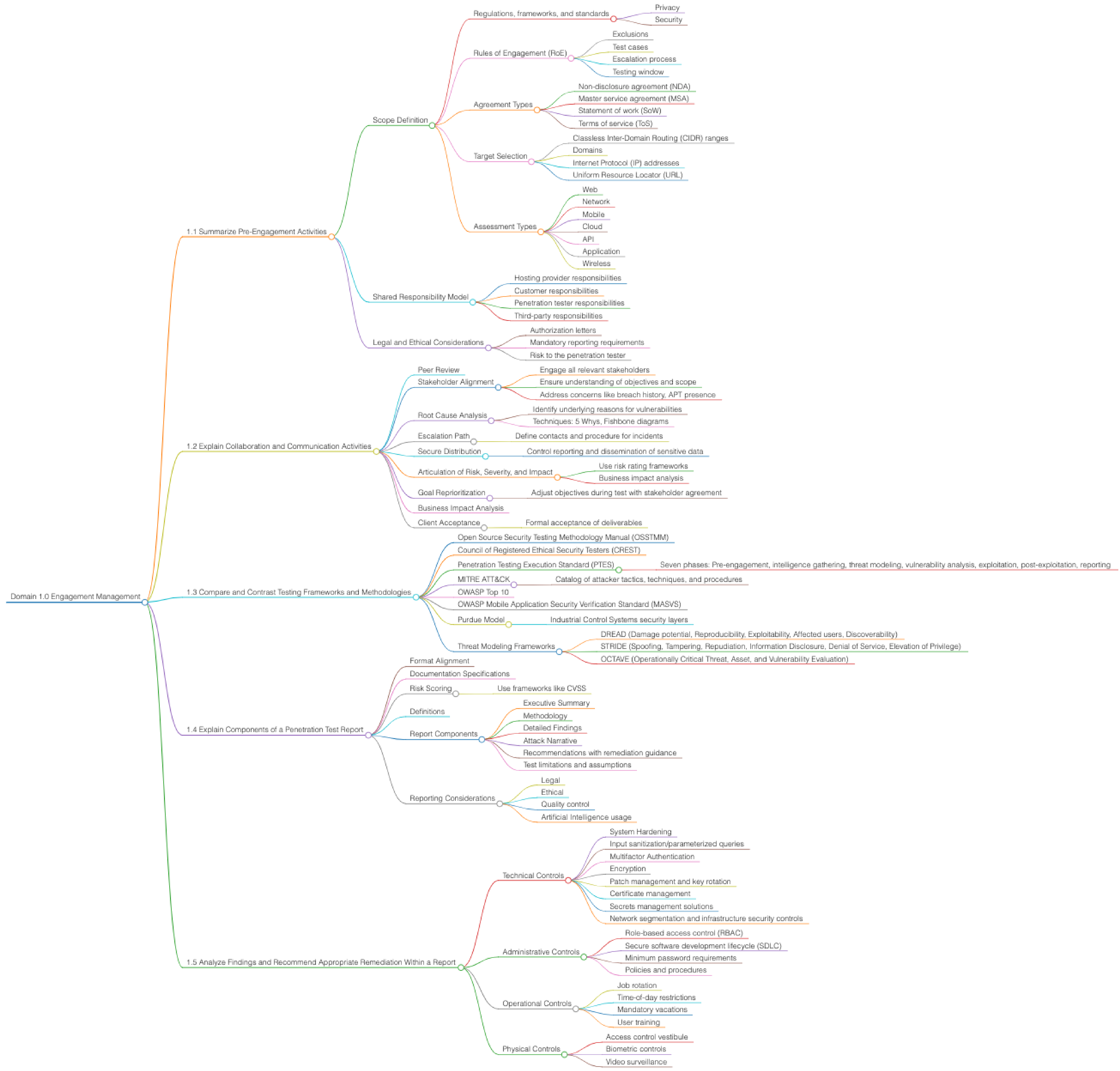

- Domain 1.0 Engagement Management
  - 1.1 Summarize Pre-Engagement Activities
    - Scope Definition
      - Regulations, frameworks, and standards
        - Privacy
        - Security
      - Rules of Engagement (RoE)
        - Exclusions
        - Test cases
        - Escalation process
        - Testing window
      - Agreement Types
        - Non-disclosure agreement (NDA)
        - Master service agreement (MSA)
        - Statement of work (SoW)
        - Terms of service (ToS)
      - Target Selection
        - Classless Inter-Domain Routing (CIDR) ranges
        - Domains
        - Internet Protocol (IP) addresses
        - Uniform Resource Locator (URL)
      - Assessment Types
        - Web
        - Network
        - Mobile
        - Cloud
        - API
        - Application
        - Wireless
    - Shared Responsibility Model
      - Hosting provider responsibilities
      - Customer responsibilities
      - Penetration tester responsibilities
      - Third-party responsibilities
    - Legal and Ethical Considerations
      - Authorization letters
      - Mandatory reporting requirements
      - Risk to the penetration tester
  - 1.2 Explain Collaboration and Communication Activities
    - Peer Review
    - Stakeholder Alignment
      - Engage all relevant stakeholders
      - Ensure understanding of objectives and scope
      - Address concerns like breach history, APT presence
    - Root Cause Analysis
      - Identify underlying reasons for vulnerabilities
      - Techniques: 5 Whys, Fishbone diagrams
    - Escalation Path
      - Define contacts and procedure for incidents
    - Secure Distribution
      - Control reporting and dissemination of sensitive data
    - Articulation of Risk, Severity, and Impact
      - Use risk rating frameworks
      - Business impact analysis
    - Goal Reprioritization
      - Adjust objectives during test with stakeholder agreement
    - Business Impact Analysis
    - Client Acceptance
      - Formal acceptance of deliverables
  - 1.3 Compare and Contrast Testing Frameworks and Methodologies
    - Open Source Security Testing Methodology Manual (OSSTMM)
    - Council of Registered Ethical Security Testers (CREST)
    - Penetration Testing Execution Standard (PTES)
      - Seven phases: Pre-engagement, intelligence gathering, threat modeling, vulnerability analysis, exploitation, post-exploitation, reporting
    - MITRE ATT&CK
      - Catalog of attacker tactics, techniques, and procedures
    - OWASP Top 10
    - OWASP Mobile Application Security Verification Standard (MASVS)
    - Purdue Model
      - Industrial Control Systems security layers
    - Threat Modeling Frameworks
      - DREAD (Damage potential, Reproducibility, Exploitability, Affected users, Discoverability)
      - STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege)
      - OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation)
  - 1.4 Explain Components of a Penetration Test Report
    - Format Alignment
    - Documentation Specifications
    - Risk Scoring
      - Use frameworks like CVSS
    - Definitions
    - Report Components
      - Executive Summary
      - Methodology
      - Detailed Findings
      - Attack Narrative
      - Recommendations with remediation guidance
      - Test limitations and assumptions
    - Reporting Considerations
      - Legal
      - Ethical
      - Quality control
      - Artificial Intelligence usage
  - 1.5 Analyze Findings and Recommend Appropriate Remediation Within a Report
    - Technical Controls
      - System Hardening
      - Input sanitization/parameterized queries
      - Multifactor Authentication
      - Encryption
      - Patch management and key rotation
      - Certificate management
      - Secrets management solutions
      - Network segmentation and infrastructure security controls
    - Administrative Controls
      - Role-based access control (RBAC)
      - Secure software development lifecycle (SDLC)
      - Minimum password requirements
      - Policies and procedures
    - Operational Controls
      - Job rotation
      - Time-of-day restrictions
      - Mandatory vacations
      - User training
    - Physical Controls
      - Access control vestibule
      - Biometric controls
      - Video surveillance